



THE LAB · ENTRY 01 · FINDING

The grant is user-shaped, *not data-shaped.*

Connect an assistant to your mailbox and the narrowest permission that lets it read one message lets it read every message. Connect it to your drive and the default search corpus is, in the publisher's own words, files *owned by or shared to* you. There is no supported way to say *my files, except the folder the legal team shared with me*. The unit of restriction is the application. It is never the data.

Edition v2 · 12 September 2026

Live page riskmandate.ai/lab-connector-grants.html

Published by RiskMandate · CC BY 4.0

This is a dated edition of a page that changes. The Lab holds our current thinking, and current thinking moves. This PDF does not: it is what we thought on the date stamped below, kept so the reasoning can be followed rather than only its conclusion. The live page may since have been corrected, extended or withdrawn — and if it has, the edition list on it will say so.

Four scopes, in their publishers' own words.

Each of these was read on 12 September 2026 from the linked page, and quoted rather than paraphrased. Nothing below required an account, a test or a request to anybody's system.

“View your email messages and settings.”

The description of `gmail.readonly` – the narrowest Gmail scope that returns a message body. The only scope that excludes bodies is `gmail.metadata`, described as “view your email message metadata such as labels and headers, but not the email body”, and it cannot read a message. There is no scope that filters by sender, label or date. · [developers.google.com – Gmail API scopes](https://developers.google.com/gmail/api/scopes)

“Files owned by or shared to the user.”

Google's definition of the user corpus – and corpora defaults to user. So on day one, the default search over a Drive grant spans everything any colleague, client or counterparty has ever shared with that person, without anybody choosing it. · [developers.google.com – Drive files.list](https://developers.google.com/drive/api/v2/list)

“Site-specific permissioning (using *.Selected permissions) is not supported because the underlying search is tenant-wide.”

Anthropic's security guide for its own Microsoft 365 connector, describing why the narrowing mechanism Microsoft provides cannot be used. The same page states that shared-mailbox access is read-only via `Mail.Read.Shared`, and that the connector uses delegated permissions so a user reaches only data they already have permission for. · [support.claude.com – Microsoft 365 connector security guide](https://support.claude.com/microsoft-365-connector-security-guide)

`account_info.read` · `files.metadata.read` · `files.content.read` ·
`files.content.write` · `sharing.read` · `sharing.write` · `file_requests.read` ·
`file_requests.write`

The eight scopes requested by the official Dropbox MCP server. Two of them are write scopes and two are sharing scopes. There is no folder-scoped variant. · [help.dropbox.com – connect the Dropbox MCP server](https://help.dropbox.com/develop/mcp-server)

The unit of restriction is the application and the tool. It is never the data.

Every lever these products offer turns a capability on or off for an assistant. None of them narrows *which material* that capability reaches. That is the finding, and it is why a behaviour policy for a connector shape is a different document from one for a coding agent: the question stops being *how far can it reach* and becomes *whose material is in reach*.

THE FAIR READING

Nobody is exceeding **your own access**.

This is the objection a vendor would raise first, it is correct, and stating it makes the finding stronger rather than weaker.

- **A delegated connector reaches what you can already reach, and no more.** Anthropic's own guide says so in as many words: users can only access data they already have permission for, and cannot bypass sharing settings or folder permissions. No privilege is being escalated.
- **The problem is not escalation. It is that there is no floor.** Your own access is the *only* boundary on offer. If your mailbox contains a client's confidential correspondence — and it does — then so does the grant, and no setting in any of these products separates the two.
- **Which is exactly what the barrier model already says.** A switch the agent's own account can flip is not a control. A connector toggle you can turn back on in one click is a setting, not a boundary — and the only real boundary available is revoking the whole connector. **The four barriers.**
- **And the default posture is permissive.** On an unconfigured business domain at the largest provider, third-party application access is allowed until an administrator changes it, so a person can connect an assistant to their work mailbox with nobody asked.

THE DEMONSTRATION

In four places, the advertised capability and **the granted scope disagree**.

These are not accusations. Marketing copy and scope lists are written by different people at every company on earth and nothing reconciles them. It is, however, precisely the condition a

behaviour policy exists to surface — so this table is the product's value in one figure.

WHAT IS ADVERTISED	WHAT THE SCOPES IN THE GRANT PERMIT	STATE
Share, move and trash files	The grant's two file scopes are a read-only scope and a per-file scope. Neither authorises acting on a pre-existing file the assistant did not create	unresolved
Create, update and delete calendar events	The publisher's own scope list for that service, as granted, is read-only	unresolved
Label and unlabel mail threads	Neither scope in the published grant authorises label mutation. A <code>gmail.labels</code> scope exists and does permit it — it is not in the grant	unresolved
Search files	Whether the shared-drive parameters are set is undocumented, so whether team drives are in the corpus in practice cannot be determined from the pages	undocumented

These stay unresolved, on purpose.

Each could be settled in an afternoon by connecting an assistant and trying it. We will not: probing somebody else's system to find out what it does is out of bounds here, with no research exemption. An unresolved contradiction, sourced to both of a vendor's own pages and dated, is worth more than a resolved one obtained by poking. If a vendor tells us which page is right, this table changes and says so.

Sources for the table, all read 12 September 2026: [Gmail scopes](#) · [Drive scope classifications](#) · [shared-drive parameters](#) · [the official server's scope list](#) · and the connector descriptions those scope lists sit behind.

WHAT THE MODEL IS MISSING

Reach answers how far. It does not answer whose.

The published capability grammar gives every primitive a reach — `project` , `host` , `tenant` , `world` , `self` — and an `undo` class. Neither says anything about who the material belongs to, and for a connector shape that is the only interesting question.

- `read.record.mailbox` would say the agent can read a mailbox. It would not say that the mailbox contains correspondence from clients who never agreed to any of this.

PROPOSED PROPERTY	VALUES	MEANING
material	OWN ORGANISATION THIRD_PARTY MIXED	Whose material the capability reaches

Almost every connector capability is mixed , and that is the finding.

A mailbox is mixed. A shared drive is mixed. A personal notes folder is own . The value of the property is that mixed **cannot be made own by any setting any of these vendors offers** — which is the user-shaped finding expressed as data rather than as a paragraph, and therefore computable.

This is a proposal against somebody else's published data, not a change we can make. It is written up as a request, with its evidence, at [Lab 03](#).

WHICH LAW REACHES FIRST

Data protection, before the AI regulation.

- A mailbox is mostly other people's writing. A shared folder is mostly other people's files. So a connector grant is, by construction, a grant over material that was entrusted rather than owned — and that is a provision, not an analogy.
- **The sub-delegation provision is one sentence.** A processor shall not engage another processor without the prior written authorisation of the controller, and the first remains liable for the second. Connecting an assistant to a mailbox of client correspondence is that sentence, in the form a stranger already recognises.
 - **Every organisation already has somebody accountable for data protection.** Almost none has anybody accountable for the AI regulation — whose deployer obligations were deferred to 2 December 2027 and reach only systems in the high-risk annex. Mapping to the instrument that already has an owner is the difference between a finding somebody acts on and one they file.
 - **And here is the honest gap.** No regulator has addressed head-on the case of third-party personal data sitting in somebody's mailbox being disclosed to an assistant by that person's own consent. The nearest published hook is a national regulator's January 2026 assessment, which warns about systems connected to databases not needed for their task and flags the difficulty of assigning controller and processor roles through the supply chain. **That is a hook, not a ruling**, and any policy we publish cites it as exactly that.

OPEN

What we cannot answer yet.

Real questions, published so nobody has to rediscover them. If you know the answer to one of these, that is the most useful thing you could send us.

- **A connector that exists and is switched off** is not in the grant today and is one click from being in it. Neither the barrier model nor the label has a place for that state, and it is probably the most common state in any real estate.
- **Does material belong in the shared capability data or in the policy?** It is a property of a capability *in a context*, which argues for the policy. It is reusable across every policy of the same shape, which argues for the data.
- **What does the mandate elicitation look like for a connector?** For a coding agent the mandate is a job. For a mailbox it is closer to a relationship, and nobody has drafted those questions.
- **Who replies if a vendor disputes one of the four contradictions?** The sourcing is theirs and the publication is ours.

If this is your product and we have it wrong, tell us and this page changes, with a line saying what changed and when. We quoted your documentation rather than testing your service precisely so that this conversation could be a correction rather than a dispute.

• Lab 01

This is what the first five policies are for.

Five deployment shapes, each one a document that makes the sentence above visible for a setup somebody actually runs. The flow that produces them — and what buying one would look like — is drawn next door.



THE LAB · ENTRY 02 · MOCKUP

From a stranger's first question to *a key they can hand an underwriter.*

Twelve stages. The first four need no account, no integration and no access to anybody's environment — they are five documents and a page. The rest is one engineering build, and it is the same build every time, which is the only reason any of this could be a business.

Edition v2 · 12 September 2026

Live page riskmandate.ai/lab-abp-flow.html

Published by RiskMandate · CC BY 4.0

This is a dated edition of a page that changes. The Lab holds our current thinking, and current thinking moves. This PDF does not: it is what we thought on the date stamped below, kept so the reasoning can be followed rather than only its conclusion. The live page may since have been corrected, extended or withdrawn — and if it has, the edition list on it will say so.

Twelve stages. Four of them are documents.

Stages one to four are the whole sales motion and they are shippable now. Stages six to ten are a single build — a template vault that gets cloned per customer — and that build is the product even though nothing on this site sells it.

STAGE	WHAT HAPPENS	STATE
1 Encounter	A stranger reads the question and recognises themselves in it	ships now
2 Self-select	Which of these five shapes is yours	ships now
3 Draft	The pre-computed policy for that shape. Free, instant, no account	ships now
4 Correct	They tell us where it is wrong. The conversion and the elicitation are the same move	ships now
5 Purchase	On the store, against the tiers that already exist	rail exists
6 Provision	Clone the template vault, seed it with the corrected draft	needs the template
7 Elicit the mandate	The only part that genuinely needs a person, or a good enough question set	needs the questions
8 Measure the grant	From the shape, the credentials and the connectors actually enabled	needs the library
9 Compute	Delta, label, leaflet. All derived, none authored	needs the computation
10 Deliver	The vault, and a read key they can share with anybody	needs the template
11 Live	Recompute when an input moves. The history is the business case	needs a receiver
12 Uplift	The twin, the score, the standards mapping — signed by somebody who did not sell stages one to ten	later

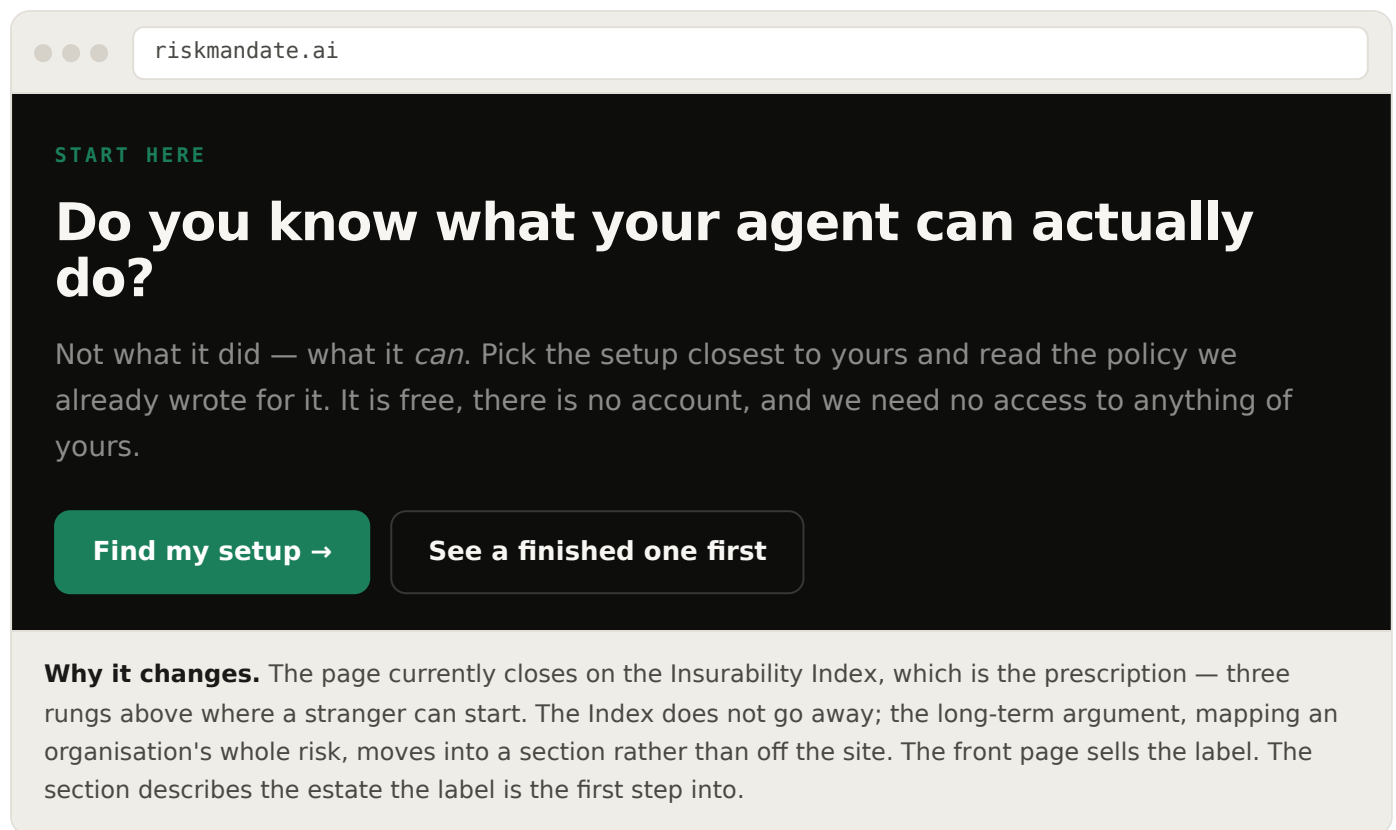
The first policy will be made by hand. If the second one costs the same, there is no business.

So the thing being built is not a document and not even a vault — it is the **template** plus the **shape library**. The marginal cost of a policy is the cost of its shape, and shapes are reused. The target is explicit: the second policy of a shape already in the library should take minutes, not days. If it does not, the library is not working and nothing should be priced yet.

MOCKUP 1 · STAGE 1

Encounter. The question, one example, the link.

A panel on this site's front page, in the place currently held by the Index. The sequence is: do you know what your agents can do → here is one → buy one. The question and the examples belong to the free library; the offer belongs here.



MOCKUP 2 · STAGE 2

Self-select. Five shapes, and one of them is yours.

Five, not fifty. Build the coding agent first because it is already in the published data and proves the method with no new research. Then the mailbox and the personal drive, which a stranger

recognises. Then the work mailbox and the corporate file estate, which are the ones somebody buys.

STEP 1 OF 2

Which of these is closest to yours?

Close is close enough. The draft is about a deployment *shape*, not about your estate — you will correct it in a minute, and the correcting is the useful part.

An assistant connected to my personal mailbox

Gmail, Outlook, or similar, connected to a chat assistant

► draft ready · 2 min read

An assistant connected to my work mailbox

The same grant, a different consequence — shared mail is in scope

draft ready · 3 min read

An assistant connected to my personal cloud drive

Drive, Dropbox, or similar

draft ready · 2 min read

An assistant connected to our corporate file estate

SharePoint, a tenant-wide search, an enterprise connector

draft ready · 4 min read

A coding agent on a developer machine

With confirmation prompts on, or off — we drafted both

draft ready · 2 min read

None of these

Tell us what you run and we will say whether we can draft it

a conversation

The honest bit. “None of these” is a real option and it goes to a person, because a shape we have not built is days of work and pretending otherwise would waste everybody's time. The five that are ready say so; nothing here implies a sixth exists.



The draft. Free, instant, and deliberately understated.

This is the screen everything else exists to reach. Four numbers, then the capability rows with what stands in the way and whose material each one touches, then the table no template can carry. Every row says where it came from.

DRAFT BEHAVIOUR POLICY · NOT YOURS YET

An assistant connected to a personal mailbox

Derived from vendor documentation read on 12 September 2026, not from your account. **We have assumed a conservative mandate.** If the numbers below look wrong, they are — and telling us how is the next step.

GRANT	MANDATE	EXCESS	UNBOUNDED
7	2	5	5

CAPABILITY		BARRIER	MATERIAL	IN THE MANDATE
read.message.tenant		expectation — a rule in prose	MIXED	yes
read.record.history		none	MIXED	no
send.message.world		setting — you can flip it back	ORGANISATION	yes
read.credential.host		none	THIRD_PARTY	no
send.endpoint.world		none	MIXED	no
create.record.world		expectation — a rule in prose	MIXED	no
read.record.browsing		setting — you can flip it back	MIXED	no

Five of seven capabilities are MIXED or THIRD_PARTY. That is not a setting you have wrong. There is no supported way to say *my inbox, except messages from outside the company* — the unit of restriction is the connector, not the correspondence.

WHERE THE VENDOR'S OWN PAGES DISAGREE	ADVERTISED	GRANTED
label mutation	label and unlabel mail threads	no scope in the grant authorises it · unresolved
calendar writes	create, update and delete events	the granted scope list is read-only · unresolved

PROVENANCE

7 of 7 capability rows **derived** from published documentation, 0 measured. Mandate assumed, not elicited. Delta computed from both, pinned to the versions shown. Valid for the deployment shape described, as at 12 September 2026 — *if the risk changed, the deployment changed, not this document*. No score appears anywhere in this document and none will.

This is wrong in places — let me correct it

Download as it stands

Understated on purpose. The assumed mandate is generous to the reader: it credits them with having authorised more than they probably did, so the correction goes *upward*. That is the moment somebody realises the grant is bigger than they thought — the same mechanic as the permission game, on a page instead of in a quiz. **And no score, anywhere.** Four counts, a barrier per row, and whose material it touches. The number a buyer can actually move is *unbounded*, and it only moves when a real control appears.

MOCKUP 4 · STAGE 4

Correct. The conversion and the elicitation are one move.

Nobody needs telling what they asked the agent to do — they need telling what it can do. So the draft asserts the mandate and asks to be corrected, and correcting it *is* stating the mandate. This is the stage nobody has rehearsed and the one most likely to be wrong.

STEP 2 OF 2 · ABOUT 90 SECONDS

Which of these did you actually ask it to do?

We guessed two. Everything you add moves a row out of the excess and into the mandate — and everything you leave is authority nobody scoped.

Read your mail so it can answer questions about it –
`read.message.tenant`

☒ asked for☐ no

Draft and send replies on your behalf – `send.message.world`

☒ asked for☐ no

Read every message anyone has ever sent you, including attachments
– `read.record.history`

☐ asked for☒ no

Reach any host on the internet while doing it – `send.endpoint.world`

☐ asked for☒ no

Read credentials stored where it runs – `read.credential.host`

☐ asked for☒ no

You authorised 2 of 7. The other five are in the grant regardless, and none of them has a barrier above the connector — so the only lever that removes any of them is disconnecting it.
Your corrected policy is yours to keep from £10, as a file with your answers, the measured grant, and the delta between them.

[Make it mine — £10](#)[Just email me the draft](#)

Two things this must not do. It must not tell anybody their setup is dangerous — a policy describes and does not judge, and the same grant is fine in one deployment and serious in another. And it must send nothing anywhere: this is a form about a deployment shape, not a probe of the reader's account, which is what makes it legal to run with a stranger in ninety seconds.

MOCKUP 5 · STAGE 10

Deliver. A key, not an attachment.

What is sold is a clone of a template vault, seeded with the customer's own corrected draft. Nothing in it is authored except the mandate — the only thing the customer knows and we do not. And the read key is the part that is worth more than it sounds.

Northgate Financial — assistant, work mailbox

mandate.json	elicited from you – the only authored file
grant.json	measured · 4 of 11 rows, 7 derived
delta.json	derived · inputs pinned
label.md	computed
leaflet.md	computed
history/	3 recomputes since 12 Sept
validity.md	as at 12 September 2026

[illegible]

Publish it publicly

BEFORE ANYTHING IS PRICED

Instrument the first five, and publish the table.

Time each one. Count how many rows were derived rather than measured, how many questions had to go to a human, and which stage was slowest. That table is the only pricing input anybody will have, and publishing it is the same discipline as everything else here.

- **Build five first** — the coding agent — because it is already in the published data and proves the method with no new research.
- **Then one and three**, the personal mailbox and the personal drive, because a stranger recognises them.
- **Then two and four**, the work mailbox and the corporate file estate, because those are the ones somebody buys.
- **Every one is derived, not measured.** The rows come from vendor documentation read on a date, not from observation — and the provenance line says so, in the same place the published capability map says 21 of 99 rows were measured.

Open, and it decides the front page: which of the five becomes the worked example a stranger meets first? Two and four are what somebody buys. One and three are what somebody understands. We think one, and we are not confident.

• Lab 02

Tell us which screen is wrong.

These are drawings. Changing them costs an afternoon now and a rewrite later, so this is the cheapest moment this flow will ever be. Stage four is the one we are least sure of.



THE LAB · ENTRY 03 · PROPOSAL

What we need from *the model site*.

The Agent Behaviour Policy model, its capability grammar and its data live at **abp.sgit.ai**, which is a separate site with a separate maintainer. We render against it. These are the three things we need in order to ship the flow next door — published here rather than emailed, so the reasoning is checkable and the answer can be public too.

Edition v2 · 12 September 2026

Live page riskmandate.ai/lab-abp-requests.html

Published by RiskMandate · CC BY 4.0

This is a dated edition of a page that changes. The Lab holds our current thinking, and current thinking moves. This PDF does not: it is what we thought on the date stamped below, kept so the reasoning can be followed rather than only its conclusion. The live page may since have been corrected, extended or withdrawn — and if it has, the edition list on it will say so.

A `material` property, because reach does not answer whose.

The 23 primitives each carry a reach — `project` , `host` , `tenant` , `world` , `self` — and an `undo` class. For a connector shape that is not the interesting question. `read.record.mailbox` says the agent can read a mailbox. It does not say the mailbox is full of other people's correspondence.

PROPERTY	VALUES	MEANING
material	<code>OWN</code> <code>ORGANISATION</code> <code>THIRD_PARTY</code> <code>MIXED</code>	Whose material the capability reaches

- **A property, not a fourth dimension.** A fourth element multiplies the grammar; keeping the model simple matters more than expressiveness here. One property on an existing primitive is the minimum change that makes the connector shapes renderable.
- **The value of it is that `mixed` is a dead end.** A mailbox is `mixed`. A shared drive is `mixed`. A personal notes folder is `own`. And `mixed` cannot be made `own` by any setting any of the four vendors we read offers — so the property turns a paragraph of argument into something computable.
- **Evidence is in Lab 01**, with four verbatim quotes from vendor documentation and their URLs, read 12 September 2026.
- **One open question we cannot settle for you.** `material` is a property of a capability *in a context*, which argues for it living in a policy rather than in the shared vocabulary. It is also identical across every policy of the same shape, which argues for the vocabulary. We lean towards the vocabulary with a per-policy override, but it is your model.

Four connector shapes, published like the first five.

There are five worked examples today and they are all about *where an agent runs*. The four below are about *whose material it reaches*, which is the stronger argument and the one a stranger recognises. Same treatment as the existing five: derived from published data, each stating how many rows were measured.

#	SHAPE	WHAT IT DEMONSTRATES	PRIORITY
1	Assistant connected to a personal mailbox	The narrowest scope that reads a message reads every message	first
2	Assistant connected to a work mailbox	Shared mail is in scope, and no administrator was asked	third
3	Assistant connected to a personal cloud drive	The default corpus is files owned by <i>or shared to</i> the user	second
4	Assistant connected to a corporate file estate	Site-specific narrowing is unsupported because the search is tenant-wide	fourth

- **Every one is derived, not measured.** The rows come from documentation read on a date, not from observation, and nothing may be tested — so the provenance line matters more here than in the existing five.
- **Each needs a section the current examples do not have:** where the vendor's advertised capability and their granted scope disagree, sourced to both of their pages, dated, and published *unresolved*. Four such contradictions are already written up in Lab 01. That section is the thing no competitor's template can carry.
- **Publish them with read keys**, like the demonstrations already on the platform site. The public examples are the library; a customer's own policy is private. That split is the whole free/paid line.

REQUEST 3 · THE CONVENTIONS

Three conventions we need in order to render anything.

We are a consumer of your data. These are the parts of the contract that are currently implicit, and each one is something we would otherwise have to guess at and get wrong.

- **A per-row provenance field, machine-readable.** The site says 21 of 99 rows are measured, which is exactly the right disclosure — but it is prose. We need it per row (`measured` / `derived` , the source URL, the date read) so a rendered policy can carry the same honesty without us re-deriving it.
- **A stated position on the enabled-but-switched-off state.** A connector that exists and is turned off is not in the grant today and is one click from being in it. Neither the barrier model nor the label has a place for that, and it is probably the most common state in any real estate. We will render whatever you decide; we cannot decide it for you.

- **A version and a shape identifier we can pin to.** The delta is stored with its inputs pinned, which only works if the inputs have stable identifiers. `versions/index.json` gives us the site version; what we need is the identity of a *shape* and of the vocabulary it was computed against, so a recompute can say what moved.

Nothing here asks you to change the hard rules. No score, describes and does not judge, derived and never authored, no claim about a third party without a source and a date. Every request above is inside those, and Request 3 exists because we want to inherit them rather than reimplement them.

HOW TO REPLY

And whether this should be a vault instead.

This page is the fastest thing to link, which is why it exists. It is probably not the right long-term home, and the alternative is better in three specific ways.

- **A page can only be answered somewhere else.** You would reply on your site, or in a message, and neither ends up next to the request. A shared vault with write access on both sides makes the request and the answer the same artefact.
- **A vault versions the conversation.** These requests will change as we learn things. A page silently replaces its own history; a vault keeps it, which is the discipline both sites already claim.
- **A read key makes it public without making it editable** — the same mechanism both of our sites already use for everything else. Publishing a cross-team request list under a read key is a better demonstration of the model than another page describing it.
- **Against it:** it needs a vault provisioned and a key exchanged, which is minutes of work neither of us has done yet, and this page is linkable now. **Our suggestion:** use this page for this round, and if there is a second round, move to a vault and keep this page as a pointer to it.

Reply however suits. Publish a response on your own site and we will link it from here; open a vault and send us a write key; or answer in whatever channel is already open. If you tell us a request is wrong, this page changes with a line saying what changed and when — same rule as everything else in the Lab.

Written 12 September 2026 against abp.sgit.ai v0.2.0 and store.sgit.ai v0.1.1, both read the same day. The brief these requests come out of is a dev brief dated 12 September 2026; the findings behind Request 1 are in [Lab 01](#) and the flow they unblock is in [Lab 02](#).

● Lab 03

Three requests, one of them small.

Request 1 is a single property on an existing model. Request 3 is three fields and a stated position. Request 2 is real work, and it is the one that unblocks a product — so if only one of the three happens, it should be that one.



THE LAB · ENTRY 04 · PROPOSAL

Seven things to build, and *one word we have not earned.*

The first thing anybody will ever use is a page that asks what they run, computes what they granted, and hands them the gap. This is its build specification: three tools, two vaults, two documents — and the arithmetic that says a twenty-connector question is not anonymous, which changes what may leave the browser.

Edition v1 · 12 September 2026

Live page riskmandate.ai/lab-shape-collector.html

Published by RiskMandate · CC BY 4.0

This is a dated edition of a page that changes. The Lab holds our current thinking, and current thinking moves. This PDF does not: it is what we thought on the date stamped below, kept so the reasoning can be followed rather than only its conclusion. The live page may since have been corrected, extended or withdrawn — and if it has, the edition list on it will say so.

WHAT THIS IS

The cheapest product we have, and it asks one thing.

Every other route into what an agent can do requires something to be installed. This one asks. Somebody says which assistants they use, on which surfaces, with which connectors switched on; the page works out what that grants; and it hands back the difference between that and what they would have said they intended. No install, no administrator, no procurement.

- **It is stages two to four of the flow next door, collapsed into one screen.** [Lab 02](#) draws twelve stages from a stranger's first question to a delivered policy. Self-select, draft and correct are three of them, and the finding here is that they are not three conversations — they are one page where the picture on the right changes as the answers on the left do, and correcting it is done by changing an answer rather than by writing to us.
- **The output already has a name.** It is *the shape* — the deployment shape, which is the noun the model site already uses for a configuration somebody actually runs. The collector produces a shape record and the grant is derived from it. No new noun.
- **It is also the whole of the smallest paid thing.** Their answers, their measured grant, the delta between them, as a file they keep. That is what the first tier on [the pricing page](#) describes, and until now it has been a questions page waiting for a tool.
- **And it is honest about what it is not.** This finds what people will tell you. That is a different thing from what is on the network, and neither one is complete. That sentence belongs on the product, not in a footnote — see [below](#) for why nobody else says it.

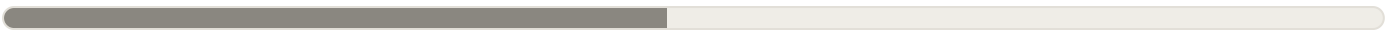
The collector asks the shape, computes the grant, and returns the delta.

Everything on this page after that sentence is about one question: what, if anything, is allowed to leave the browser.

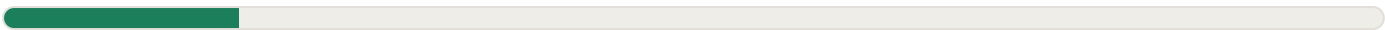
THE ARITHMETIC

A twenty-connector question is **not anonymous**.

The instinct is that answers like these are harmless in bulk, so they can simply be collected. That instinct is wrong, and it is wrong measurably rather than arguably — which is the good case, because it means the fix is arithmetic rather than judgement.



2²⁰ — about a million distinct answers to one question.



4 bands × 2⁵ category combinations = 128 answers. A reduction of about 8,000×, and the research loses almost nothing — the interesting finding is *how many* and *of what kind*, not which brand.

One benchmark makes the first bar concrete. A browser-uniqueness study of 470,000 samples measured about 18 bits across a whole fingerprint — user agent, plugins, fonts, screen, timezone, the lot — and found 83.6% of visitors instantaneously unique on it. **Our connector question, on its own, carries more entropy than that entire fingerprint.**

RESPONSES	CELLS THAT COULD HOLD A GROUP OF FIVE	REALISTIC OUTCOME
100	at most 20	Effectively every respondent unique
500	at most 100	Effectively every respondent unique
5,000	at most 1,000	Common shapes reach a group of five. Every interesting shape does not
50,000	at most 10,000	The head is safe and the tail still singles out

- **The nominal space is around five trillion cells** once assistants, surfaces, role and company size are multiplied in — roughly 42 bits. Real distributions are skewed, so far fewer cells are ever occupied. The comparison that decides the question is not with the space, it is with the number of respondents, and at any sample we will plausibly reach, the respondents lose.
- **The regulator's test is singling out** — the ability to isolate the records relating to one person — assessed against a motivated intruder assumed reasonably competent with ordinary resources, and it cites groups of five as strong protection. Nothing in the table above reaches that.
- **A second anchor, from outside our field entirely.** Three low-cardinality fields — postcode, gender and date of birth — uniquely identify about 87% of a national population. A configuration is a fingerprint in the literal sense, and fingerprints do not become less identifying because the person typed them in themselves.

- **So the submissions are personal data and must be handled as such.** That is not an argument against building it. It is an argument for building it the way described next, which costs almost nothing and makes the product better.

Where the banding lands us, honestly. Applied across every field, the banding cuts the nominal space from about 42 bits to about 20 — a factor of roughly four million, and the single largest reduction available to us. It also leaves a banded submission at *approximately the entropy of that browser fingerprint*. Banding is therefore the necessary first move and not the whole answer: the submission only stops singling people out once [suppression on output](#) and [a written assessment](#) exist alongside it. This paragraph is our own arithmetic, derived from assumptions we have shown rather than measured from data we do not have.

THE RESOLUTION

Compute locally in full. **Submit banded.**

This keeps everything the product needs and gives up nothing the user wants. The full configuration is computed in the browser and never leaves it; what crosses the wire, and only if somebody presses submit, is a banded record.

STAYS ON THE MACHINE

The full shape, and everything derived from it

Every connector by name, every surface, every assistant. The grant is computed from the full shape, the delta derived, the label and the leaflet rendered. The user sees all of it. It is their configuration.

- named** connectors, assistants, surfaces
- computed** grant, delta, barriers
- typed** anything written freely
- kept** in this browser, to be resumed

EXPLICIT
SUBMIT
ONLY

MAY CROSS THE WIRE

Bands and categories. Nothing else.

A record with no names in it, no identifier of any kind attached to it, and nothing recorded about the request that carried it.

- band** connector count, 4 values
- categories** mail, files, calendar, code, chat
- coarse** desktop, web, editor, command line
- bands** role (3–4), company size (3)

FIELD	FULL, LOCAL	SUBMITTED
connectors	The named list of twenty	A count band — none, 1-2, 3-5, 6+ — plus categories : mail, files, calendar, code, chat
assistants	The named list	A count band and the categories
surfaces	Each one	Coarse — desktop, web, editor, command line
role	Free choice	Three or four bands
company size	Exact	Three bands
free text	Shown back to them	Never submitted. Free text cannot be anonymised
address, user agent, precise time	Not needed	Never recorded — each one independently defeats the banding

A collector that cannot read back cannot correlate.

That is the estate's own enforcer test — a control bounds a grant only if it is enforced by something the grant does not include — applied to our own product. A promise not to correlate is bounded only by something the collector does not have, and here that something is read access. It is a structural claim rather than a policy, which is the only kind worth publishing.

- **The write-only lane between two vaults is therefore not a platform demonstration.** It is the correct privacy architecture for this specific job, and saying so turns a capability into an argument. The submitting side holds a write credential and no read key; it cannot join a submission to an earlier one, cannot read across respondents at the point of collection, and cannot reconstruct a session — because it cannot read anything at all.
- **One hard rule follows, and it goes in the build rather than in a policy.** A submission carries *no stable identifier of any kind*. Not a session token, not an install identifier, not a hash of anything, not a salted hash, not a "random" value that persists past the page. The pattern to copy is the install counter that refuses identifiers outright and buckets by week.
- **Suppress on output, and check the subtraction.** Never render a published cell backed by fewer than five submissions, and verify that a suppressed cell cannot be recovered by subtracting the ones around it from a total. The second half is the part that gets forgotten.

WHAT HAS TO BE BUILT

Three tools, two vaults, two documents.

Nothing below exists. Each card says what the thing is, where it runs, what it holds, what it must never do, and what has to be decided before it can be started. The two documents are on this list because without them the product cannot use the word it wants to use.

T1 The shape collector

TOOL · BROWSER

The page itself: under fifteen questions, one item per screen on a phone, an honest stated duration, a picture that accumulates on the right as the answers come in on the left, one guess screen before the reveal, and a result the user can keep. Everything it computes, it computes locally.

RUNS	Entirely in the browser. Static page, no build step, works from a file on disk — the same constraint as every page on this site.
HOLDS	In-progress answers in local storage, so a half-finished assessment survives a reload. Strictly necessary — see the two regimes — so no banner.
PRODUCES	A shape record (T2), the grant derived from it, the delta, and a file the user keeps.
NEVER	Sends anything on its own. Submission is a separate, explicit, unticked act on its own screen.
BLOCKED ON	Open questions 1 , 2 and 3 — the exact question count, whether connectors are one multi-select or category-then-count, and what the guess screen asks.

T2 The shape record schema

DOCUMENT · OPEN DATA

A closed, controlled vocabulary for a *deployed configuration*: which assistant, on which surface, with which connectors granted which scopes — and the mapping from that to the capability primitives it grants. Twice this month the answer to "do we need to build this" has been "it already exists". Not this time.

WHY	Every standard in the area describes the artefact and none describes the deployment . The machine-learning component bill of materials, standardised as an international specification in December 2025, describes a model: parameters, task, architecture family, datasets, inputs, outputs, considerations. The other bill-of-materials family has an equivalent profile. Neither says which assistant a person runs, on which surface, with which connectors. That is a genuine gap.
REUSES	The published capability grammar — verb, object, reach — from abp.sgit.ai . The schema's whole job is to map a configuration to a set of those primitives, and nothing more.
DISCIPLINE	Derive rather than assert. Every row from a connector to the capabilities it grants carries a source, a date, and whether it was measured or derived. That material is the research in Lab 01 , and the per-row provenance field it needs is Request 3 on the model site .
NEVER	Gets called an ontology. The value is the closed vocabulary, not the formalism around it.
BLOCKED ON	Open question 7 — whether this publishes early and invites correction, or stays internal until enough policies exist to know its shape.

V1 The submitting vault

VAULT · WRITE-ONLY

The lane the browser hands a banded record to. It holds a write credential for V2 and no read key for anything, which is what makes the privacy claim structural instead of promissory.

CAN	Write one banded record into the collection vault.
CANNOT	Read. Not its own writes, not V2, not a previous submission. This is enforced by the absence of a read key rather than by code we wrote.
CARRIES	The banded record and a week bucket. No stable identifier of any kind.
RECORDS	No address, no user agent, no precise timestamp. Each of those independently defeats the banding, which makes them a build rule rather than a preference.
BLOCKED ON	Nothing. This one can be provisioned today, and is the smallest piece of the seven.

V2 The collection vault

VAULT · APPEND-ONLY

Where banded records accumulate. Read access sits with us and not with the collector, which is the entire point of splitting it from V1.

HOLDS	Banded records, one per submission, bucketed by week. Nothing that could be joined to a person, a session, or another record.
VERSIONED	By the vault, so the corpus has a history rather than a current state — the same discipline the rest of the estate claims.
NEVER	Holds free text. Not in a notes field, not in an "other" box, not in a bug report pasted into it later.
BLOCKED ON	Open question 6 — the suppression threshold, which is a property of what we publish from here rather than of the vault itself, but which should be decided before anything lands in it.

T3 The aggregator

TOOL · OURS

The thing that turns a collection vault into something publishable, and the only place the suppression rule can actually be enforced. It is listed separately because a rule that lives in prose is not a rule.

ENFORCES	No published cell backed by fewer than five submissions — and a check that a suppressed cell cannot be recovered by subtracting its neighbours from a published total.
PUBLISHES	Cells, bands, and counts. Where the threshold bites, it says a cell was suppressed rather than showing a zero, because a silent zero is a lie about the data.
NEVER	Returns a row. Not to us on a dashboard, not to a customer, not in an export. There is no legitimate use for an individual banded row that a suppressed cell does not serve better.
BLOCKED ON	Open question 6, and on V2 holding enough that suppression does not simply hide everything — which it will, early on, and the page should say so rather than wait.

D1 The motivated-intruder assessment

DOCUMENT · SHORT

A short written assessment naming who the motivated intruder would be, what they would already know, and what the banded corpus would add to it. The obligation is not to reduce the risk to zero; it is to make a reasoned assessment and record it.

WHY IT IS ON THE BUILD LIST	Because it is a precondition for a word , not a compliance chore. Until it exists, the product may not say <i>anonymous</i> — see below .
NAMES	For the public mode: somebody who reads the published cells and wants to identify a respondent. For the employer mode: the buyer , which is an uncomfortable sentence and the correct one.
LIVES	Published, on this site, dated, and revised when the instrument changes. An assessment nobody can read is indistinguishable from one nobody wrote.
BLOCKED ON	Open question 4 — who writes it. It is a short document and it gates the language on the product, which makes it the highest ratio of consequence to effort on this page.

T4 The employer instrument

TOOL · SECOND PRODUCT

The same questions, sent by an employer to its own staff, to find out how many agents are in use. It is a real second product and it is *not the same product*, because the law changes when the employer sends the link. Detail in [its own section](#).

DIFFERS BY	Lawful basis, an impact assessment, and the output. Probably not by the instrument — same questions is cheaper, and the consent problem does not care which questions are asked.
NEVER	Returns an individual row to the employer. Only cells above the suppression threshold, only bands — and the page the employee sees says so before they answer.
REQUIRES	Its own impact assessment before it runs. That is a piece of work, not a paragraph, and it is not D1 with the names changed.
BLOCKED ON	Open question 5 , and on T1 existing. This is fourth in order and first in revenue, which is a tension worth naming rather than resolving early.

Order, if only some of it happens. V1 and V2 are hours and unblock the honest version of everything else. T1 is the product. D1 is a short document that decides what T1 is allowed to say, so it should not trail the build. T3 can wait until there is anything to aggregate, but its rule has to be agreed before T1 ships or the first publication will breach it. T2 is the largest piece and the one with outside value. T4 is the largest revenue and the largest legal surface, and it should not be started while T1 is still moving.

TWO REGIMES

Storing the answers is one thing. Sending them is another.

The analysis splits cleanly, and the design should follow the split rather than cover the whole tool with one consent banner. Three of these four rows need no banner at all. The fourth needs more than a banner.

OPERATION	REGIME	POSITION
storing in-progress answers	Storage rules, in scope	Strictly necessary. Assessed from the user's point of view, and somebody who starts a self-assessment plainly wants their answers to persist. No banner
reading them back	Storage rules, in scope	Same exception, same reasoning
analytics about the tool	Storage rules, in scope	Drop-off point, device class, which question loses people. The statistical-purposes exception fits , with clear information and a simple free means to object — a toggle defaulted on. Browser settings are not sufficient
submitting the answers	Not the storage rules. Data protection only	An explicit, separate, unticked act. The answers are the content the user produced, not statistics about how the service is used

The statistical exception covers *how* a service is used. It does not cover *what* the user told it.

Those are different things and only the first is exempt. The regulator is explicit that the exception is not a broad one covering all analytics — which means the submit screen is a real screen, with its own unticked control, and not a line in a footer.

This is research, not legal advice. The split above is read off the regulator's own published guidance, on a stated date, and the citations are at the bottom of this page. An impact assessment for the employer mode is a piece of work rather than a paragraph, and nothing here substitutes for it.

COMPLETION

Do not design it as a game. Design it to finish.

The instinct that the game framing carries over from the teaching work is wrong, and the evidence that applies here is a different literature. This is a data-collection instrument, not a teaching artefact: what matters is completion, and that literature is well developed and mostly contradicts the folklore.

PROGRESS INDICATOR	EFFECT ON DROPPING OUT
constant speed – an honest linear bar	No significant effect
fast at first, then slowing	Drop-off odds multiplied by about 0.80
slow at first, then speeding up	Drop-off odds up by 56%

- **The harmful pattern is exactly what this tool produces by accident.** A short introductory section followed by a long connector-by-connector section makes the bar stall in the middle — which is the slow-then-fast shape, the one that raises drop-off odds by more than half. The meta-analysis behind the table covers nineteen studies and thirty-two experiments and concludes that its findings question the common belief that progress indicators reduce drop-off at all.
- **One question per screen does not reliably buy completion either.** A controlled comparison of a conversational form against an ordinary one found 89.8% against 91.4% completion — no significant difference — and the conversational version took **53% longer**. A 2026 field experiment found it rated more original and more entertaining, harder to navigate, and with no practical data-quality advantage.
- **And the widely quoted commercial figure does not survive inspection.** A conversational-form vendor claims 47.3% completion against a stated industry average of 21.5%, with no methodology, no denominator definition and no independent verification. Its companion claim about rich media is an uncontrolled correlation between finishing a form and how much effort somebody put into building it.

RANK	LEVER	EVIDENCE
1	Fewer questions	The only lever with both randomised and large observational support, and the observational data shows a cliff above roughly fifteen
2	An honest, short stated duration	Randomised and replicated. The announcement is itself a treatment , and an indicator only helped when the task was promised short and actually was
3	Works on a phone, one item at a time, no grids	Strong on quality, good on completion. Most responses will be mobile
4	A high-value question early	One clean experiment, one large observational study. Modest but real
5	Showing partial results	Satisfaction significantly higher, completion roughly unchanged. Treat as an untested hypothesis

- **The accumulating picture is still worth building, for the honest reason.** It makes the thing feel worth finishing and it makes the output legible. It is *not* evidenced as a completion mechanism, so it should be measured rather than assumed — which is the fifth row of the table above, not the first.
- **One game mechanic earns its place, and it is the estate's own.** Before revealing what the selected connectors grant, ask the user to guess the number. Stating a belief before being shown the answer is the mechanic the games site is built on; it costs one screen; and it is what makes the result land rather than scroll past. It is also what turns a form into the experience the game instinct was reaching for, without the 53% time penalty of a conversational interface.

Which assistants — multi-select, one screen	1
Which surfaces — coarse, four options	1
Which connector categories — mail, files, calendar, code, chat	1
How many in each selected category — a band per category	2 typical · 5 worst
Role — three or four bands	1
Company size — three bands	1
The guess — a belief stated before the reveal, not a data question	1
Submit — an explicit unticked act, not a question	1
Screens before the result	9 typical · 12 worst case

That is the budget, and it is the constraint everything else negotiates against. Under fifteen, an honest stated duration, one item per screen on mobile, a front-loaded progress indicator or none at all, and one guess screen before the reveal. Every feature proposed after this page has to say which screen it is taking, or which one it replaces.

THE SECOND PRODUCT

When the employer sends the link, the law changes.

The same instrument, circulated inside a company to find out how many agents are actually in use, is a real product and a different one. Three things move, and the third is the one that decides the design.

- **Consent stops working.** The regulator's guidance on monitoring workers says consent is not usually appropriate in the employment context because of the imbalance of power, and that it must be freely given and withdrawable without detriment. A survey circulated by an employer, whose answers could reveal a policy breach, is close to the worst case for freely given consent. The realistic basis is legitimate interests with a documented assessment.

- **An impact assessment is likely required before it runs.** One must be carried out before processing likely to cause high risk to workers' interests, and a tool that inventories which systems an individual employee uses, on which devices, with which data connectors, is systematic monitoring of workers.
- **And the employer holds the identifying context we do not.** The regulator recognises relative anonymity explicitly: information can be personal data in one organisation's hands and anonymous in the hands of another that lacks the context. The employer has the organisation chart, the device fleet and the sign-on logs.

"One product person on a desktop assistant with mail, files and code connectors" is anonymous to us and a name to them.

So the employer mode never returns an individual row. Only cells above the suppression threshold, only bands, and the product says so on the page the employee sees before they answer.

The privacy constraint and the data-quality constraint are the same constraint. A version that could return a row is also the version an employee answers carefully rather than honestly. Suppression is not a concession extracted from the product here — it is the only reason the answers would be worth collecting.

THE MARKET

Nobody else asks. That is the opening and the problem.

A ten-vendor comparison of the discovery market, published 7 September 2026, found that all ten discover through technical telemetry — browser extensions, endpoint agents, network inspection, API integrations, sign-on logs — and none through self-report. One free assessment tool disparages self-report explicitly and recommends usage telemetry instead. Both halves of that matter.

THE OPENING

Self-report reaches what telemetry cannot

A personal device, a personal account and a locally run server are all invisible to every method on that list, and all three are where the interesting deployments are. One of the larger vendors implicitly concedes the gap by selling desktop agents to close it.

no procurement
no installation
no administrator

○ SAME
FACT

THE PROBLEM

There is no vocabulary of trust for it

No incumbent treats survey data as a legitimate discovery source, so the burden of explaining why it counts falls entirely on us — and it cannot be met by claiming more than the method delivers.

says what people will tell you
not what is on the network
neither one is complete

- **The completion standard to beat is a free seven-question organisational assessment** taking about two minutes, with no email gate. That is the bar, and our budget above is nine screens — so the honest stated duration has to be honest.
- **And nothing we found asks an individual which assistants and connectors they personally use and returns them a result.** That is the specific thing being built, and it is the reason this is worth doing at all.

LANGUAGE

The honest word, until then, is banded.

One sentence of product copy is doing more damage than any missing feature on this page, and it is the one that says the data is anonymous. It is a claim with a defined test behind it, and we do not currently pass the test.

The word *anonymous* may not appear in this product until all three of these exist:

1. **The banding** — no named connector list, no free text, no address, no user agent, no precise time, no stable identifier. *Specified above; not built.*
2. **The suppression** — no published cell below five, and the subtraction check alongside it. *Specified above; not built.*
3. **The assessment** — written down, naming the motivated intruder, published and dated. *Not written.*

- **Until then the product says *banded*,** and explains what that means in a sentence: we ask how many and of what kind, never which brand, and never anything you typed. That is a claim we can currently support, which is the only kind this site publishes.
- **This is the same rule the rest of the site runs on.** No claim about a third party without a source and a date; no score without stated inputs; no capability asserted without saying whether it was measured or derived. A privacy claim is not exempt from the discipline just because it is about us.

OPEN QUESTIONS

Seven things we **cannot settle alone.**

These are real rather than rhetorical, and four of the seven block a card in the build list above. If you have an opinion on any of them, that is more useful to us today than agreement with the rest of the page.

#	QUESTION	BLOCKS
1	How many questions, exactly? The cliff is around fifteen and the connector question alone could be twenty items if built carelessly	T1
2	Is the connector question one multi-select, or a category then a count? The second is the banding made native, and it may lose people who want to see their own tool named	T1
3	What does the guess screen ask? One number, or one number per category	T1
4	Who writes the motivated-intruder assessment, and where does it live? It is a short document and it is a precondition for a word	D1
5	Does the employer mode need a different instrument, or the same one with a different output? Same instrument is cheaper, and the consent problem does not care	T4
6	What is the suppression threshold? Five is the cited standard, and a small early sample will suppress nearly everything	T3 · V2
7	Does the shape schema become the published vocabulary, or stay internal until the fifth policy? Publishing early invites correction and locks a shape too soon	T2

HONEST TENSIONS

And seven we are **choosing to live with.**

TENSION	BOTH HALVES ARE TRUE
banding the submission	It is what makes the data lawful to hold, and it throws away the brand-level detail that would be the most interesting thing to publish
computing locally	It is the strongest privacy position available, and it means we learn nothing at all unless somebody presses submit
not designing it as a game	The evidence is about completion rather than enjoyment, and the instinct about feel is what will make people start
the guess screen	It is the one mechanic with a published argument behind it, and it adds a screen to an instrument whose main lever is fewer screens
employer mode	It is a real second product, and it carries an impact assessment, a weak lawful basis, and an intruder who is the buyer
self-report	It reaches what telemetry cannot, and no incumbent treats it as legitimate
building the schema	It is a genuine gap, and it is the third schema this estate has taken on in a fortnight

What this page deliberately is not. It is not a schema — the gap is established and the disciplines are named, but no field is defined. It is not a design — question count, ordering and the accumulating picture are constrained by evidence, and nothing is drawn. It is not legal advice. It is not a privacy claim, for the reason in [the section above](#). And it is not a completion promise: the evidence constrains the design and predicts nothing whatsoever about our numbers.

Written 12 September 2026 from a dev brief of the same date. Sources, all read 12 September 2026 – **completion:** the progress-indicator meta-analysis of 19 studies and 32 experiments, Villar, Callegaro and Yang 2013, *Social Science Computer Review* 31(6); the expectation-matching result, Yan, Conrad, Tourangeau and Couper 2011, *IJPOR* 23(2); the conversational comparison, Kim, Lee and Gweon 2019, CHI; the 2026 field experiment, Cavusoglu Deveci, Fuchs and Metzler, *BMS* 169-170(1), 6 March 2026; the item-by-item finding, Revilla, Toninelli and Ochoa 2015; the personalised-feedback trial, Kühne and Kroh 2018, *SSCR* 36(6); vendor completion claims at typeform.com, treated as marketing with no methodology. **Schemas:** cyclonedx.org, machine-learning component bill of materials v1.7, standardised as an international specification December 2025; the alternative family's profile at spdx.github.io/spdx-spec. Neither describes a deployed configuration. **Identifiability:** the regulator on effective anonymisation, the singling-out test, the motivated-intruder test and groups of five, at ico.org.uk; Sweeney on postcode, gender and date of birth; Eckersley 2010 on 470,000 browser samples and 83.6% instantaneous uniqueness. **Storage and submission:** the guidance on storage and access technologies, published 29 April 2026, at ico.org.uk, including the strictly-necessary test assessed from the user's point of view, the statistical-purposes conditions, the objection mechanism that may not be a browser setting, and the statement that the exception is not a broad one covering all analytics. **Employment:** the regulator on monitoring workers, October 2023 and last updated 16 June 2026, at ico.org.uk. **The market:** a ten-vendor comparison published 7 September 2026; nudgesecurity.com for the one transparent price found; the free seven-question assessment at aona.ai, which recommends telemetry over self-report. **Inside the estate:** the capability map and its 23 primitives at what-can-it-do.games.sgit.ai; the belief-before-answer mechanic at games.sgit.ai. The entropy arithmetic in [the second section](#) is ours, derived from stated assumptions rather than measured.

● Lab 04

Two vaults are hours. One word is a document.

The write-only lane can be provisioned today and it is what makes the privacy claim structural rather than promissory. The assessment is a short piece of writing and it decides what the product is allowed to say. Neither is the hard part, and both are ahead of the hard part.